

VAPT INTERNSHIP

WEEK 4 Scanning and Enumeration

Sulav Adhikari

1. SECTION A - Multiple Choice Questions

VAPT Internship — Nepal | Week 4
Quiz: Scanning and Enumeration

sulavadh124@gmail.com [Switch accounts](#)
Not shared Draft saved

* Indicates required question

Section A

1. Which Nmap flag is used for SYN scan? *

☐ A. -sT
☐ B. -sU
☒ C. -sS
☐ D. -sV

2. What does the -sn flag do in Nmap? *

☐ A. Scan ports
☐ B. Detect OS
☒ C. Host discovery only
☐ D. Run scripts

3. Which scan type completes the full TCP handshake? *

☐ A. SYN scan
☐ B. UDP scan
☒ C. TCP Connect scan
☐ D. Xmas scan

4. Which port is commonly used by SMB? *

☐ A. 21
☐ B. 22
☐ C. 80
☒ D. 445

5. What does -p- mean in Nmap? *

☐ A. Scan top 1000 ports
☐ B. Scan specific port
☒ C. Scan all ports
☐ D. Skip ports

VAPT Internship — Nepal | Weebly

docs.google.com/forms/d/e/1FAIpQLSfWpIzdlM_ykY_dGvksAZGk6T2aKY7zM2RXN6F_mWKbghtg/formResponse?pli=1

☐ D. Skip ports

6. Which tool is used for SMB enumeration? *

☐ A. Nikto

☐ B. Gobuster

☒ C. enum4linux

☐ D. Wireshark

7. What is the purpose of Gobuster? *

☐ A. Scan vulnerabilities

☒ B. Brute-force directories

☐ C. Capture packets

☐ D. Encrypt data

8. Which command checks FTP anonymous login? *

☐ A. nmap -sV

☒ B. nmap --script=ftp-anon

☐ C. ftp connect

☐ D. gobuster ftp

☒ B. nmap --script=ftp-anon

☐ C. ftp connect

☐ D. gobuster ftp

9. What does "filtered" port state mean? *

☐ A. Port is open

☐ B. Port is closed

☒ C. Firewall blocking response

☐ D. Service crashed

10. Which command is used for banner grabbing? *

☐ A. ssh

☐ B. ftp

☒ C. nc

☐ D. ping

[Back](#) [Next](#) [Clear form](#)

Never submit passwords through Google Forms.

This content is neither created nor endorsed by Google. - [Contact form owner](#) - [Terms of Service](#) - [Privacy Policy](#)

Does this form look suspicious? [Report](#)

Google Forms

2. SECTION B - Short Answer Questions

VAPT Internship — Nepal | Weebly

docs.google.com/forms/d/e/1FAIpQLSfWplzZdIM_ykY_dGvks4ZGk6T2aKY7zM2RXN6F_mWkbghtg/formResponse?pli=1

sulavadh124@gmail.com [Switch accounts](#)

Not shared Draft saved

* Indicates required question

Section B

1. Explain different types of Nmap scans with examples. (5 marks) *

Nmap is a network scanning tool used to discover hosts, open ports, services, and operating systems.

Types of Nmap scans:

- SYN Scan (-sS)**
It is called a half-open scan because it does not complete the full TCP handshake. It is fast and stealthy.
Example: `nmap -sS 192.168.1.1`
- TCP Connect Scan (-sT)**
It completes the full TCP handshake. It is used when SYN scan is not allowed.
Example: `nmap -sT 192.168.1.1`
- UDP Scan (-sU)**
Used to scan UDP ports like DNS and SNMP.
Example: `nmap -sU 192.168.1.1`
- Version Detection (-sV)**
Detects service versions running on open ports.
Example: `nmap -sV 192.168.1.1`
- OS Detection (-O)**
Identifies the target operating system.
Example: `nmap -O 192.168.1.1`

VAPT Internship — Nepal | Weebly

docs.google.com/forms/d/e/1FAIpQLSfWplzZdIM_ykY_dGvks4ZGk6T2aKY7zM2RXN6F_mWkbghtg/formResponse?pli=1

2. What is SMB enumeration? Explain tools and commands used. (5 marks) *

MB (Server Message Block) is a protocol used for file sharing, printer sharing, and network communication in Windows systems. It commonly runs on port 445.

SMB enumeration means collecting information such as shared folders, users, groups, and system details from a target machine.

Tools used:

- enum4linux**
Used to enumerate SMB shares, users, groups, and policies.
Example: `enum4linux 192.168.1.10`
- smclient**
Used to connect and list shared folders.
Example: `smclient -L //192.168.1.10 -N`
- Nmap SMB scripts**
Example: `nmap --script smb-os-discovery 192.168.1.10`

3. Explain Web Enumeration using Nikto and Gobuster. (5 marks) *

Web enumeration is the process of gathering information about websites, directories, files, and vulnerabilities.

- Nikto**
Nikto is a web vulnerability scanner used to detect outdated software, dangerous files, and security issues.
Example: `nikto -h http://192.168.1.20`
It checks for:
- Server misconfigurations
- Default files
- Vulnerable versions
- Security headers

VAPT Internship — Nepal | Web

docs.google.com/forms/d/e/1FAIpQLSfWplzZdIM_ykY_dGvksAZGk6T2aKY7zM2R0N6F_mWKbgtg/formResponse?pli=1

b) Gobuster
Gobuster is used for brute-forcing hidden directories and files on web servers.
Example:
gobuster dir -u http://192.168.1.20 -w wordlist.txt
It helps find:
-Hidden admin panels
-Backup files
-Login pages
-Secret directories
Both tools are important for web application testing.

4. What is Banner Grabbing? Explain with examples. (5 marks) *

Banner grabbing is the process of collecting service information from open ports, such as software name, version, and server details.
It helps attackers and security testers identify services running on the target.

Tools used:
a) Netcat (nc)
Example: nc 192.168.1.10 80
Then type:
HEAD / HTTP/1.0
This may show server details like Apache or Nginx version.
b) Telnet
Example: telnet 192.168.1.10 21
It may display FTP server banner like: 220 FTP Server Ready
c) Nmap Version Detection
Example: nmap -sV 192.168.1.10
Banner grabbing helps in identifying outdated or vulnerable services.

Back Submit Clear form

Never submit passwords through Google Forms.

3. SECTION C - Practical Submission Tasks

a. Task C1 - Nmap Scan Interpretation

Question	Answer
Which service on which port has a known backdoor CVE? Name the CVE.	vsftpd 2.3.4 running on Port 21 (FTP) has a known backdoor vulnerability. CVE: CVE-2011-2523
Which port should NEVER be open because all traffic is in plaintext?	Port 23 (Telnet) should never be open because it sends usernames and passwords in plaintext.
List 3 ports that expose Windows/Linux file sharing. What tool enumerates them?	139/tcp (NetBIOS), 445/tcp (SMB), 3306/tcp (MySQL). Tool used: enum4linux
What Nmap flag was used to detect these service versions? Write the full command.	Flag used: -sV . Command: nmap -sV <target-ip>
You want to run vulnerability scripts against port 445 only. Write the full Nmap command.	Command: nmap -p 445 --script vuln <target-ip>
Which OS was detected? What Nmap flag detects the OS?	Detected OS: Linux 2.6.X (Metasploitable). Flag used: -O

b. Task C2- Enumeration Screenshots

- **enum4linux**

Command used: enum4linux -a 192.168.63.128

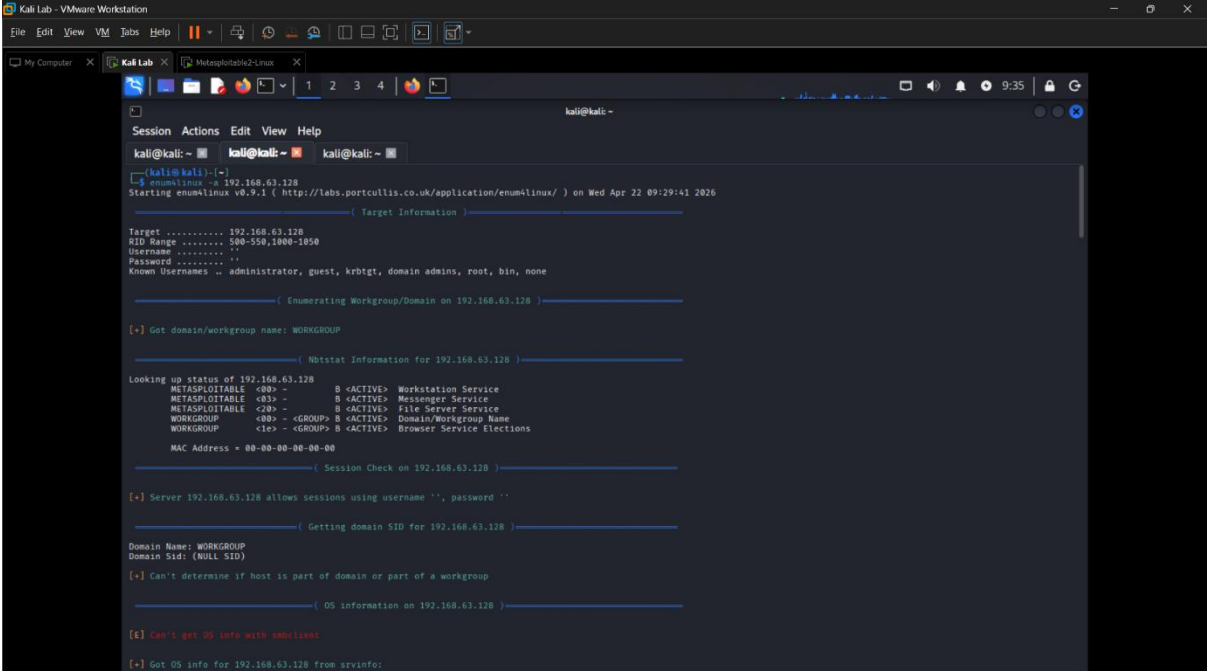
Findings: Running enum4linux -a 192.168.63.128 performed a full SMB enumeration against the Metasploitable 2 target. The tool successfully established a null session (no username or password

required), confirming a critical misconfiguration. A total of 35 user accounts were enumerated via RID cycling, including high-value accounts such as root, msfadmin, user, postgres, mysql, tomcat55, and ftp. The OS was identified as Samba 3.0.20-Debian running on the METASPLOITABLE workgroup. This unauthenticated user enumeration means an attacker can directly target these accounts for brute-force or password spray attacks against SSH, FTP, and other services.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:58:30:09
          inet addr:192.168.63.128  Bcast:192.168.63.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe58:3009:64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:54 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5131 (5.0 KB)  TX bytes:6826 (6.6 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1:128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:96 errors:0 dropped:0 overruns:0 frame:0
          TX packets:96 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21437 (20.9 KB)  TX bytes:21437 (20.9 KB)

msfadmin@metasploitable:~$ _
```



The screenshot shows a Kali Linux virtual machine running on VMware Workstation. The terminal window displays the output of the `enum4linux` command, which enumerates the target system (192.168.63.128). The output includes target information, RID range, known usernames, and a list of services running on the target. The file explorer window shows the contents of the `enum4linux` directory, including the `enum4linux` script and its output file.

```
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~
kali@kali:~$ enum4linux -u 192.168.63.128
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Apr 22 09:29:41 2026

( Target Information )
Target ..... 192.168.63.128
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

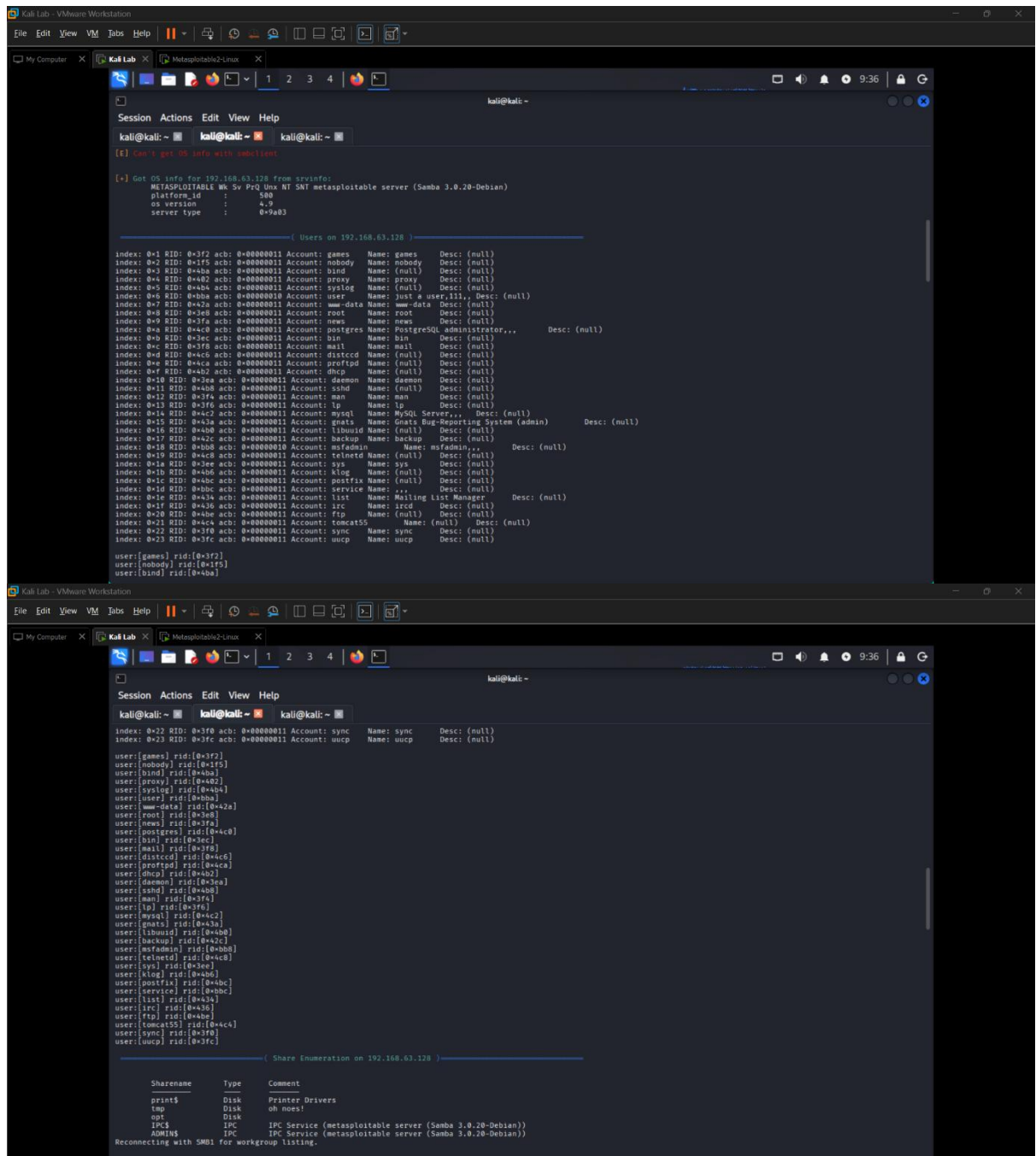
( Enumerating Workgroup/Domain on 192.168.63.128 )
[+] Got domain/workgroup name: WORKGROUP

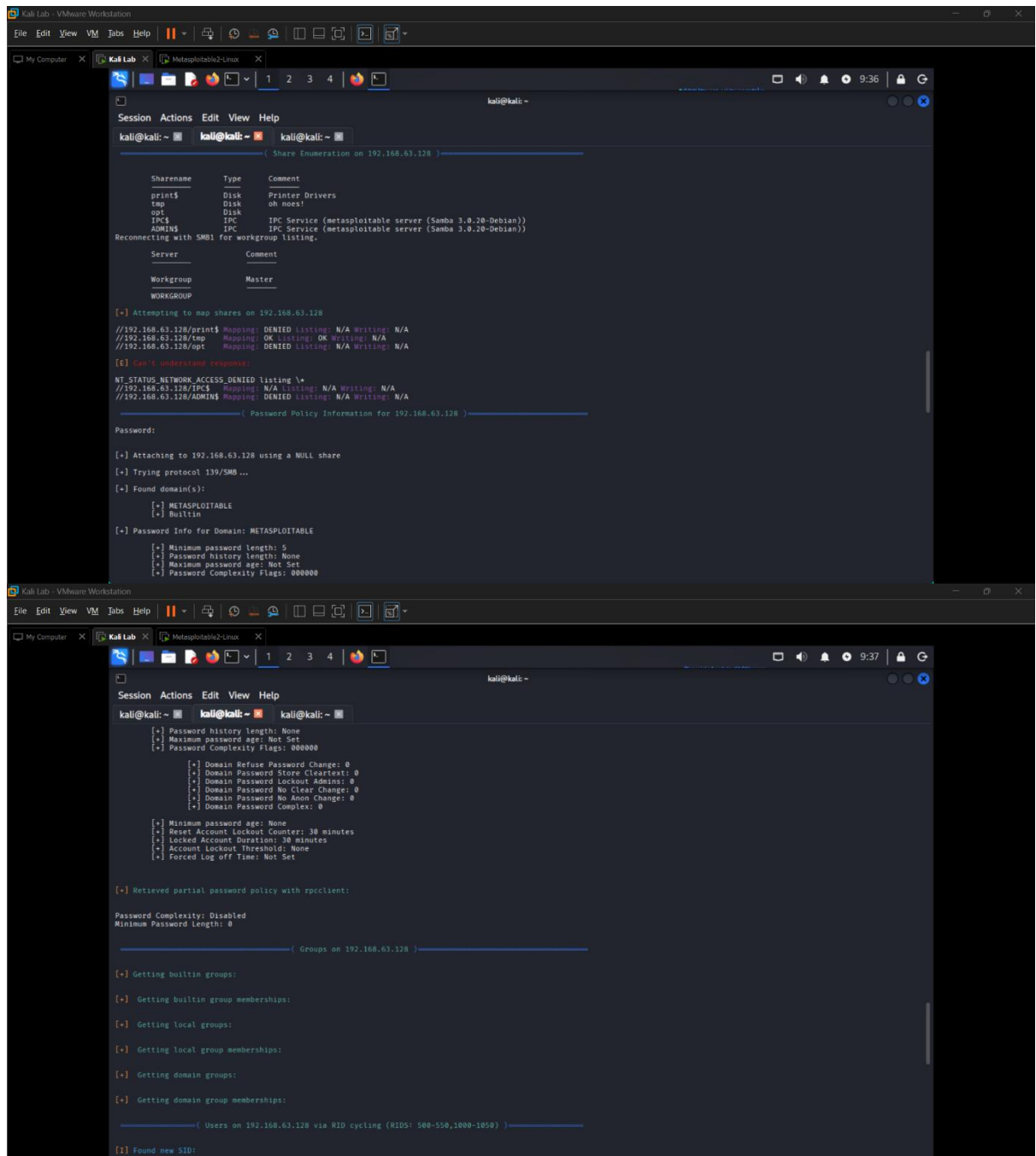
( Nbtstat Information for 192.168.63.128 )
Looking up status of 192.168.63.128
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
MAC Address = 00-00-00-00-00-00

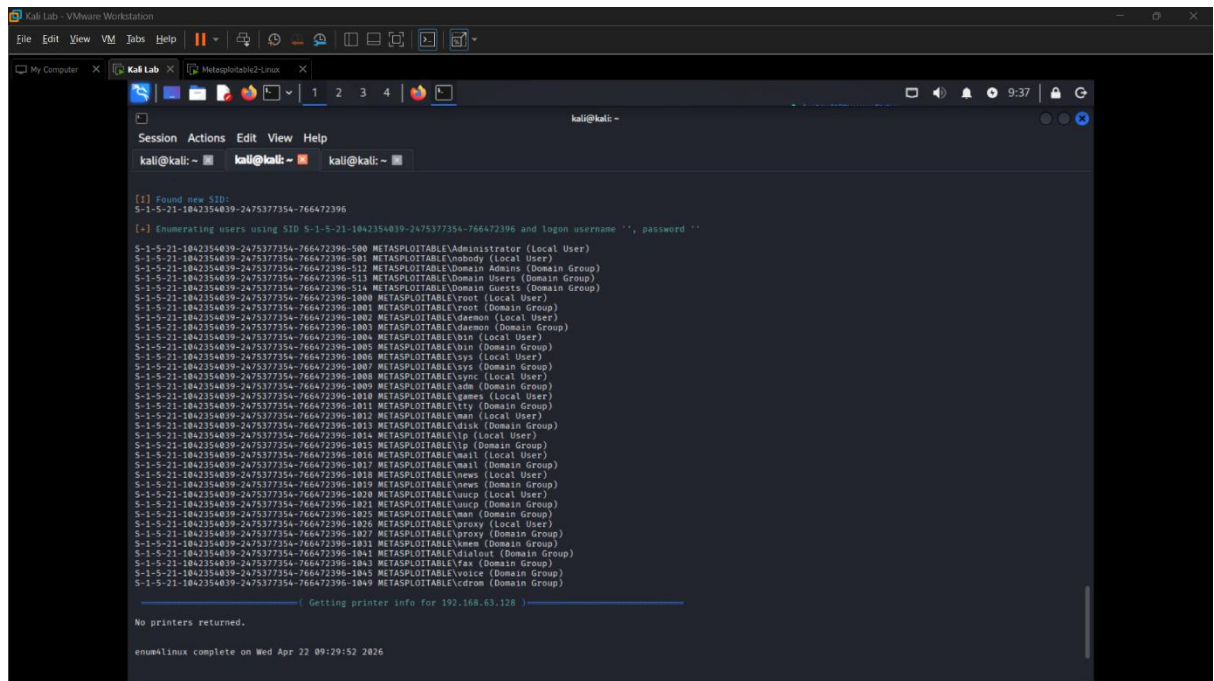
( Session Check on 192.168.63.128 )
[+] Server 192.168.63.128 allows sessions using username '', password ''

( Getting domain SID for 192.168.63.128 )
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup

( OS information on 192.168.63.128 )
[!] Can't get OS info with smbclient
[+] Got OS info for 192.168.63.128 from sruinfo:
```







Path	Status	Risk
/phpMyAdmin	301 → redirect	HIGH- database admin panel exposed
/phpinfo.php	200 OK	HIGH- exposes full PHP/server config
/phpinfo	200 OK	HIGH- same PHP info page
/dav	301 → redirect	MEDIUM- WebDAV enabled, allows file upload
/test	301 → redirect	MEDIUM- test directory publicly accessible
/twiki	301 → redirect	MEDIUM- TWiki installation found
/index.php	200 OK	LOW- main application index
/.htaccess, /.htpasswd, /.hta	403 Forbidden	INFO- access denied but files exist

/cgi-bin/	403 Forbidden	INFO
/server-status	403 Forbidden	INFO- Apache status page present

```

kali@kali: ~
└─$ gobuster dir -u http://192.168.63.128 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://192.168.63.128
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

[+] .htaccess          (Status: 403) [Size: 296]
[+] .htpasswd          (Status: 403) [Size: 296]
[+] .hta               (Status: 403) [Size: 291]
[+] cgi-bin/           (Status: 403) [Size: 295]
[+] dav                (Status: 301) [Size: 319] [→ http://192.168.63.128/dav/]
[+] index.php          (Status: 200) [Size: 891]
[+] index              (Status: 200) [Size: 891]
[+] phpMyAdmin         (Status: 301) [Size: 326] [→ http://192.168.63.128/phpMyAdmin/]
[+] phpinfo            (Status: 200) [Size: 48014]
[+] phpinfo.php        (Status: 200) [Size: 48026]
[+] server-status      (Status: 403) [Size: 300]
[+] test               (Status: 301) [Size: 320] [→ http://192.168.63.128/test/]
[+] twiki              (Status: 301) [Size: 321] [→ http://192.168.63.128/twiki/]
Progress: 4613 / 4613 (100.00%)

Finished

kali@kali: ~
└─$

```

- **Nikto:**

Command Used: nikto -h <http://192.168.63.128>

Findings: Nikto performed an automated web vulnerability scan against the target on port 80. The top findings are listed below:

SN	Finding	Risk
1	Apache/2.2.8 is critically outdated (current is 2.4.66) - multiple known CVEs exist	HIGH
2	PHP/5.2.4 is critically outdated (current is 8.5.1) - remote code execution vulnerabilities exist	HIGH
3	HTTP TRACE method is active - server is vulnerable to Cross-Site Tracing (XST) attack	HIGH
4	/phpMyAdmin exposed - database admin panel accessible without any restriction	HIGH
5	/phpinfo.php found - PHP configuration fully exposed including server paths,	HIGH

	modules, and environment variables	
6	/doc/ directory is browsable - may expose system documentation (CVE-1999-0678)	MEDIUM
7	/icons/ directory indexing enabled - directory listing is exposed	MEDIUM
8	PHP Easter Eggs enabled - sensitive version information leaked via crafted query strings	MEDIUM
9	Five security headers missing - X-Content-Type-Options, Referrer-Policy, Strict-Transport-Security, Permissions-Policy, Content-Security-Policy	MEDIUM
10	Apache mod_negotiation with MultiViews enabled - allows brute-forcing of hidden filenames	LOW

```

kali@kali: ~
kali@kali:~$ nikto -h http://192.168.63.128
- Nikto v2.6.0

+ Your Nikto installation is out of date.
+ Target IP: 192.168.63.128
+ Target Hostname: 192.168.63.128
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-04-22 09:49:04 (GMT+7.75)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-c all' to force check all possible dirs). CGI tests skipped.
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'fcgi' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing

+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /%PHPE9568F34-D428-11D2-A769-00AA003ACF42: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /%PHPE9568F35-D428-11D2-A769-00AA003ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /%PHPE9568F3A-D428-11D2-A769-00AA003ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /%PHPE9568F35-D428-11D2-A769-00AA003ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/

```

```
Kali Lab - VMware Workstation
File Edit View VM Tabs Help
My Computer x kali Lab x Metasploit2 Linux x

kali@kali: ~
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for index were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /%PHPE958F34-D428-11D2-A769-00AA001ACF42: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/wroteups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /%PHPE958F35-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/wroteups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /%PHPE958F34-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/wroteups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /%PHPE958F35-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/wroteups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 40540, mtime: Tue Dec 9 23:09:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
^C
kali@kali: ~
```